NEXUS FINANCIAL SERVICES

Governance, Risk, and Compliance (GRC) Assessment

GRC Portfolio Project

A practical review of governance, risk management, and compliance gaps in a growing financial services company, with a proposed action plan to establish a more structured GRC programme.

Assessment focus

- Governance structure and accountability
- Risk identification and assessment
- Policy management and regulatory tracking
- Recommended GRC programme improvement

Case study: Nexus Financial Services, Lagos, Nigeria

1. Executive Summary

Nexus Financial Services is a growing financial services company in Lagos, Nigeria. As the company has expanded, day-to-day decisions have outpaced its organizational structure. The case study states that policies are not consistently approved or enforced, risk is not assessed through a standard process before business decisions, and responsibility for tracking regulatory requirements and deadlines is unclear.

These issues create gaps across all three GRC pillars. Governance needs to define decision-making authority and accountability; risk management needs a repeatable way to identify, assess, and treat risks; and compliance needs clear ownership and monitoring of legal and regulatory obligations.

Overall recommendation: Leadership should sponsor a formal GRC programme with clear accountability, approved policies, a risk assessment and treatment process, and a compliance obligations register with named owners and review dates. A dedicated GRC team or designated cross-functional GRC working group can coordinate implementation, but ownership remains with leadership and the relevant business functions.

2. Project Overview

The objective is to review Nexus Financial Services' current situation, identify governance, risk, and compliance issues, categorize each issue under the correct GRC pillar, and recommend one action to improve the company's GRC programme. The board is expected to receive a briefing within 72 hours, so recommendations should be practical, prioritized, and easy to understand.

3. GRC Explained in Simple Terms

Governance defines how an organization is directed and controlled. It establishes decision-making authority, responsibilities, policies, oversight, and accountability.

Risk Management is the process of identifying what could prevent the organization from achieving its objectives, assessing likelihood and impact, and deciding how to respond. Common risk responses include avoiding, mitigating, transferring, or accepting a risk.

Compliance means identifying the laws, regulations, contractual obligations, and internal requirements that apply to the organization, then implementing and monitoring processes to meet those obligations.

Together, GRC helps an organization make accountable decisions, understand and manage uncertainty, and meet applicable obligations in a coordinated way.

4. Issues Identified and GRC Categorization

Issue from the case	Primary GRC pillar	Why it fits
No clear process for approving or enforcing company policies.	**Governance** (with compliance implications)	Policies need defined approval authority, owners, communication, and oversight. Failure to enforce them can also create compliance gaps.
No standard way to assess risk before business decisions.	**Risk Management**	Nexus lacks a repeatable process for identifying, analyzing, prioritizing, and treating risks before decisions are made.
No one is responsible for tracking regulatory requirements and deadlines.	**Compliance**	Regulatory obligations need named owners, a register, due dates, monitoring, and escalation of overdue actions.

Additional observations

The scenario also indicates that Nexus has no formal GRC framework and that business decisions are often made informally. These are broader symptoms of unclear governance and immature risk and compliance processes. The absence of separate GRC departments is not, by itself, proof of a control failure: a smaller organization can use assigned responsibilities or a cross-functional committee, provided accountability and oversight are clear.

5. Recommended Action to Improve the GRC Programme

Recommendation: Establish a leadership-sponsored GRC programme with a clear charter, named owners, and a basic set of repeatable processes.

The board or executive leadership should approve the programme and define responsibilities. A designated GRC lead or cross-functional working group can coordinate the work across operations, finance, legal/compliance, and technology. This approach creates structure without assuming Nexus immediately needs a large standalone GRC department.

Initial implementation steps

1. **Confirm governance and accountability.** Approve a GRC charter that defines decision rights, escalation paths, policy ownership, and management oversight.
2. **Create a policy management process.** Maintain a policy inventory with an owner, approver, review date, version history, and evidence of staff communication.
3. **Introduce a risk assessment process.** Maintain a risk register with risk descriptions, likelihood, impact, existing controls, risk owners, treatment decisions, and target dates.
4. **Build a compliance obligations register.** Record applicable requirements, responsible owners, evidence expectations, reporting deadlines, and escalation for overdue actions.
5. **Track remediation and report progress.** Review open risks, policy exceptions, and compliance actions with leadership on a defined schedule.

6. Proposed 30-Day Action Plan

Timing	Action	Expected output
Days 1–5	Appoint an executive sponsor and interim GRC coordinator; confirm key stakeholders and decision rights.	Named owners, initial responsibilities, and an agreed programme scope.
Days 6–12	Inventory existing policies and known legal/regulatory obligations; identify missing owners and deadlines.	Policy inventory and initial compliance obligations register.
Days 13–20	Identify and score priority business risks; agree risk owners and treatment actions.	Initial risk register and prioritized treatment plan.
Days 21–30	Approve the basic governance process, set review cadence, and present unresolved issues to leadership.	GRC operating rhythm, escalation route, and leadership reporting template.

7. Results and Findings

The case study shows that Nexus's growth has not been matched by a formal structure for governing decisions, assessing risk, and tracking compliance obligations. The three clearest issues map to the GRC pillars as follows:

- **Governance:** Policy approval and enforcement processes are unclear.
- **Risk Management:** No standard risk assessment process is used before business decisions.
- **Compliance:** No designated owner is responsible for tracking regulatory requirements and deadlines.

A formal, leadership-sponsored GRC programme would help Nexus define accountability, standardize decisions, create visibility into risk, and reduce the likelihood of missed regulatory obligations. Progress should be measured through evidence such as policy approvals, risk register updates, assigned compliance owners, and closure of overdue actions.

The scenario does not identify specific laws, regulations, actual violations, fines, or confirmed incidents. Those should be established through further assessment rather than assumed.

8. Conclusion

Nexus does not need to solve every issue at once. It needs a clear starting structure: leadership sponsorship, defined ownership, documented policies, a repeatable risk process, and a reliable way to monitor compliance obligations. These foundational practices would give the company a more consistent and accountable approach as it continues to grow.

9. Author

Project: Nexus Financial Services — GRC Assessment
Specialization: Governance, Risk, and Compliance (GRC)
Focus Areas: Governance Structure, Risk Assessment, Policy Management, Regulatory Compliance

---

Educational case study based on the supplied Nexus Financial Services scenario. This report is not a legal opinion or a formal audit of an actual organization.